

[Web Security Basics for SOC Analyst (L1 Perspective)]

These topics are very important for a SOC Analyst because attackers use them daily against websites and web applications.

As a SOC L1 Analyst, your job is not always to exploit them, but to:

- Detect attacks
- Analyze logs
- Identify malicious behavior
- Escalate incidents
- Understand attacker techniques

[1. SQL Injection (SQLi)]

[What is SQL Injection?]

SQL Injection happens when an attacker inserts malicious SQL queries into input fields like login forms, search bars, URL parameters, and contact forms. The goal is to manipulate the database.

[Example]

Normal query:

```
SELECT * FROM users WHERE username='admin' AND password='1234';
```

Attacker input: ' OR 1=1 --

Modified query becomes:

```
SELECT * FROM users WHERE username='' OR 1=1 --';
```

Result: This may bypass login authentication.

[Attacker Goals]

- Login bypass
- Steal database data
- Dump usernames/passwords
- Delete tables
- Gain admin access

[SOC Analyst Indicators]

- Look for suspicious characters: ', --, UNION SELECT, OR 1=1
- Repeated failed requests
- WAF alerts
- Database errors in logs

- High number of requests to login pages

Common Log Example:

```
GET /login.php?id=1' OR '1'='1
```

[SOC Response]

- Block attacker IP
- Check affected accounts
- Review database logs
- Escalate to IR team
- Verify WAF protection

[2. Cross-Site Scripting (XSS)]

[What is XSS?]

XSS occurs when attackers inject malicious JavaScript into a website. When users open the page, the script runs in their browser.

[Types of XSS]

```
[ XSS Vulnerabilities ]
├── Stored XSS —————> (Malicious script saved inside the database)
├── Reflected XSS —————> (Script reflected immediately through URL/request)
└── DOM-based XSS —————> (Client-side execution via browser Document Object Model)
```

Example Payload: `<script>alert('Hacked')</script>`

[Attacker Goals]

- Steal cookies
- Hijack sessions
- Redirect users
- Fake login pages
- Deliver malware

[SOC Indicators]

- `<script>` tags in logs
- Encoded payloads
- Suspicious URL parameters
- User complaints about redirects/popups
- WAF alerts

Example Log:

```
GET /search?q=<script>alert(1)</script>
```

[SOC Response]

- Identify affected users
- Remove malicious script
- Check session compromise

- Block source IP
 - Escalate to AppSec team
-

[3. Cross-Site Request Forgery (CSRF)]

[What is CSRF?]

CSRF tricks authenticated users into performing unwanted actions. Example: A logged-in user clicks a malicious link, and their account password changes automatically.

[Example Scenario]

Victim already logged into bank website. Attacker sends hidden request:

```

```

Result: Browser automatically sends session cookie.

[Attacker Goals]

- Change passwords
- Transfer money
- Modify account settings
- Perform actions as victim

[SOC Indicators]

- Unexpected account changes
- Multiple actions from same session
- Requests from unusual referrers
- Missing CSRF tokens

[SOC Response]

- Review session activity
 - Force logout users
 - Check browser history/referrer
 - Escalate suspicious account activity
-

[4. Directory Traversal]

[What is Directory Traversal?]

Attackers try to access restricted files/folders on the server. They use `../` sequences to escape the web root directory and move across the system hierarchy.

Example Log Request:

```
GET /download?file=../../etc/passwd
```

[Important Files Targeted]

```
[ Targets ]
├─ Linux  ———> /etc/passwd , /etc/shadow
└─ Windows ———> C:\Windows\System32
```

[Attacker Goals]

- Read sensitive files
- Access configurations
- Find credentials
- Discover server filesystem structure

[SOC Indicators]

- Look for `.. /` and encoded variants like `%2e%2e%2f`
- Requests for system sensitive files
- Unusual file access execution attempts

[SOC Response]

- Block malicious requests
 - Review accessed files
 - Check privilege escalation
 - Escalate if sensitive data exposed
-

[5. Command Injection]

[What is Command Injection?]

Attackers inject Operating System (OS) commands into vulnerable web applications. The application executes attacker commands directly on the server host backend.

[Example Process Flow]

```
Vulnerable Input Form —> Expected: ping 8.8.8.8
Attacker Input Execution —> Modified: 8.8.8.8; whoami
Server Terminal Execution —> [ ping 8.8.8.8 ] followed by [ whoami ]
```

Example Log Entry:

```
POST /ping?host=8.8.8.8;cat /etc/passwd
```

[SOC Indicators]

- Look for delimiters and terminal commands: `;`, `&&`, `|`, `cmd.exe`, `powershell`, `/bin/bash`
- Suspicious outbound traffic initiated after exploitation

[SOC Response]

- Isolate affected server host
 - Check running processes
 - Review EDR alert notifications
 - Hunt for malware binaries/persistence mechanism
 - Escalate immediately
-

[6. Authentication Attacks]

[What are Authentication Attacks?]

These attacks target login systems and user credentials to achieve unauthorized initial access.

[Common Types]

- **Brute Force:** Trying many password combinations against a single user account.
- **Credential Stuffing:** Using leaked username/password matrices from other public breaches.
- **Password Spraying:** Trying one single highly common password against a broad list of multiple domain user accounts.

[SOC Indicators]

- Multiple sequential failed login alerts
- Many unique user accounts targeted from a single unified IP address
- Same identical password string sprayed across many users
- Login attempts from unusual geographical regions
- Impossible travel telemetry triggers

[SOC Response]

- Lock affected account entities
- Block attacker source IPs
- Enforce multi-factor authentication (MFA)
- Investigate compromised accounts and review authentication framework logs

[7. Session Hijacking]

[What is Session Hijacking?]

Attackers steal a valid user's session token or cookie and import it to impersonate them directly without passing authorization security checkpoints.

Example Header: Cookie: PHPSESSID=abcd1234

[How Sessions Are Stolen]

```
[ Session Exfiltration Vectors ]
├─ XSS (Cross-Site Scripting payload exfiltration)
├─ Dedicated endpoint malware / Stealers
├─ Network packet sniffing (cleartext transport)
├─ Weak HTTPS cryptographic deployment
└─ Session fixation loops
```

[SOC Indicators]

- Same explicit session identifier matching different IP address points
- Sudden, unexpected user geolocation transformations
- Multiple active devices using an identical unique session cookie concurrently
- Unusual user transactional activity

[SOC Response]

- Invalidate and revoke active session cookies
- Force an immediate account password reset
- Review browser agent details and device activity logs
- Investigate account compromise markers

[Quick SOC Analyst Summary]

Attack Type	Main Goal	SOC Focus
SQL Injection	Database access	Suspicious queries & SQL strings
XSS	Execute JS in browser	Script payloads & code tags
CSRF	Abuse user session	Unauthorized user actions
Directory Traversal	Access restricted files	. . / and directory patterns
Command Injection	Execute OS commands	Shell commands & token separators
Authentication Attacks	Account takeover	Failed logins & spraying anomalies
Session Hijacking	Steal user sessions	Session telemetry changes

[SOC Analyst Practical Skills & Ecosystem]

[Essential Capabilities to Learn]

- Reading and parsing raw web server access logs
- Deconstructing HTTP requests (GET, POST, headers, cookies)
- Spotting basic SQLi payloads and XSS script tags
- SIEM and Web Application Firewall (WAF) alert analysis
- Session auditing and user authentication log analysis
- Basic threat hunting workflows

[Important Tools Used in SOC]

- **SIEM Platforms:** Splunk, Microsoft Sentinel
- **Network Analysis:** Wireshark
- **Interception & Pentesting:** Burp Suite, OWASP ZAP
- **Framework Guidelines:** OWASP Top 10

[Final Summary]

These web attacks are extremely common in real-world SOC environments. A professional SOC L1 Analyst must master how these attacks operate conceptually, what their trace signatures look like inside log files, what specific indicator patterns appear, and how to execute rapid triage steps.